

Outpost MDM

Обзор системы и список реализованных функций · версия 0.16.0 · 2026-05-18

Что это

Outpost MDM — собственная серверная система управления парком Android-устройств для тактических развёртываний. Управляет дистрибуцией APK, ML-моделей, knowledge.db, шифрованных документов, выполняет per-device настройку приложений и собирает телеметрию в Grafana через OTLP. Клиентом является приложение Outpost-Android (он же «Штаб», ru.tacticalar.outpost) из соседнего репозитория tactical-ar-hud.

Цель — заменить ручные curl-команды по зачислению устройств и копи-паст ссылок в Telegram на единый admin Web UI, через который оператор за ≤10 минут доводит новый телефон от состояния «распакован из коробки» до состояния «зачислен в MDM, шлёт телеметрию, авто-обновляется». Без adb, без режима разработчика, без app-store'ов.

Архитектура

Стек

Rust 2024 edition, axum 0.8, sqlx + SQLite (WAL, foreign keys ON), tokio async runtime, Askama-шаблоны для admin Web UI. Один статический Linux x86_64 бинарь ~6.9 МБ, развёртывание через systemd unit за nginx (TLS termination + reverse-proxy). База — single-file SQLite, бэкапы через Litestream-совместимые snapshots.

Криптография

Argon2id для паролей админов · HMAC-SHA256 для signed download URLs и cookie-binding · TOTP (RFC 6238) для 2FA · ECDH P-256 + HKDF-SHA-256 + AES-256-GCM для encrypted file distribution · AWS Signature Version 4 (через собственный port на Rust, byte-perfect верифицированный против boto3) для Cloud.ru presigned download URLs.

Фоновые задачи (tokio::spawn)

- **scheduler** — fan-out push-сообщений из push_messages по группам устройств.
- **apk_watcher** — каждые 15 минут хитит upstream apks/latest/version.txt, регистрирует свежие сборки в application_versions.
- **rollout_monitor** — каждые 60 секунд проходит по canary-раскаткам, auto-promote по canary_until_at, auto-rollback по crash-rate gate.
- **distribute_gc** — раз в сутки purge encrypted_distributions где expires_at + 7d < now(), удаляет blob с диска если ни одной active row на тот же sha256.

Реализованные функции по версиям

v0.10 — Зачисление через QR

- QR-код enrollment-payload на admin-странице `/devices/{id}/enroll`.
- Собственная URI-схема `outpost-mdm://v1/<base64url(json)>` — клиент branch'ится по схеме и не путает с RBAC.
- Manual-paste fallback (plain JSON) для случаев когда камера капризничает.
- Скачивание `enrollment.json` файлом для offline-bootstrap через флешку.
- 90-дневный `device_token` с привязкой к UID + session-tracking.

v0.11 — Автообнаружение APK

- Polling upstream `R2/Cloud.ru/GH-Releases` manifest каждые 15 минут.
- Простой `key=value` формат manifest'a (`tag`, `sha256`, `size`, `version_code`, `version_name`) — никакого версионирования схемы.
- Dedup по `sha256`: re-build с теми же source-files → один `application_versions` row, не два.
- Discovery-only, без auto-push: admin вручную решает когда катить раскатку.

v0.12 — Tier-2: lifecycle APK

- `application_rollouts`: phases *canary* → *fleet* → *rolled_back*.
- Per-device `pinned_version_id` — admin может зафиксировать конкретную версию.
- Canary group → fleet auto-promote по `canary_until_at` timestamp.
- Auto-rollback по `crash_threshold_pct` gate (default 5%).
- Resolve-policy в `/api/v1/sync`: `pin` → `fleet` → `canary`, отдаётся `update_available` если `target.version_code > device.app_version_code`.
- Admin Web UI: `/applications/{id}/rollouts` с кнопками Promote / Pause / Rollback.

v0.13 — Settings Sync (§1)

- Двусторонний контракт `/api/v1/sync`: server ↔ client с `monotonic state_version`.
- Устройство шлёт `current_state snapshot` — admin видит фактические настройки на телефоне.
- `applied_commands ack-flow`: client сообщает результат применения каждой команды (ok / error + message).
- Forward-compat: `SyncCommand.id` на проводе теперь String для UUID-ready клиентов (БД остаётся INTEGER PK).
- POST `/api/v1/devices/{id}/config` — отправить update-config patch с произвольным JSON payload'ом.

v0.14 — Per-Device Encrypted Distribution (§2)

- ECDH P-256: устройство генерирует keypair в Android Keystore StrongBox, шлёт public part серверу при enroll'e.
- AES-256-GCM шифрует blob один раз случайным DEK; DEK wrap'ится через HKDF(ECDH(eph_priv, recipient_pubkey)) для каждого recipient'a.
- Один shared blob на disk + N rows в `encrypted_distributions` с different wrapped_dek.

- HKDF info-prefix включает `file_id` + `recipient_device_id` — защита от cross-recipient replay.
- Admin Web UI `/files/{id}/distribute`: target picker device / group / fleet-wide.
- Eligible-only: устройства без `device_pubkey` (старее rc42 b37) skipping с понятным count'ом в flash-message.

v0.15 — Push-команды для admin (§3) + GC

- `rotate-cloudru-creds`: partial-rotation (только secret, или только `tenant_id`), client сохраняет в ModelPreferences + CloudRuSigner.setOverride.
- `revoke-enrollment` с required reason: soft revoke (client wipes token), `device_token` остаётся валиден пока клиент не услышит.
- `remote-wipe` со scope *app-data* или *factory-reset*: ModelPreferences + knowledge.db + models + cache, fallback на app-data на не-Device-Owner устройствах.
- `distribute_gc` background task: purge expired blobs (24h tick, 7d grace, конфигурируется через settings.distribute.gc_*).
- Admin Web UI `/devices/{id}/edit`: формы для всех трёх команд + `current_state` viewer.
- Backward-compat gate `app_version_code >= 178`: для legacy клиентов команды возвращают 400.

v0.16 — Cloud.ru APK QR на странице enrollment

- Rust port SigV4 query-string presigned URL generator: композитный `access_key` `tenant_id:key_id`, region `ru-central-1`, host `s3.cloud.ru`, path-style.
- 10 unit-тестов включая golden vector byte-perfect к Python boto3 reference.
- На admin-странице `/devices/{id}/enroll` два QR в правильной последовательности: «Шаг 1 — установка приложения» (APK) и «Шаг 2 — полезная нагрузка регистрации» (enrollment).
- Presigned URL TTL = 7 дней (SigV4 maximum). На каждый GET страницы — свежий URL.
- Прямая ссылка моноспейсом под QR для копи-паста / Telegram если камера не сканирует.
- All-or-nothing валидация env-vars `CLOUDRU_TENANT_ID/KEY_ID/SECRET` на старте сервера. Partial → baill.
- Read-only IAM scope: только `s3:GetObject` на `outpost/*`. Per-device персонифицированные creds — следующий этап.

Текущее состояние production

Параметр	Значение
Версия live	0.16.0 (с 2026-05-17 23:10 UTC)
Хост	mdm.secondf8n.tech
Endpoint	https://mdm.secondf8n.tech (TLS, nginx → 127.0.0.1:8080)
Healthz	{"status":"ok","version":"0.16.0"}
Хранение	/var/lib/outpost/outpost.db (SQLite + WAL)
Cloud.ru APK QR	включён (presigner enabled, bucket=outpost, key=apks/latest/app-debug.apk)
Tailscale	admin-сервисы (Grafana, Prometheus, node-exporter) bind на tailnet
Public	только /healthz и admin Web UI через nginx + certbot

Roadmap

Что сознательно не реализовано в 0.16 и ждёт следующих этапов. Все пункты — extensions к существующему, не breaking changes.

- **Per-device персонализированные Cloud.ru creds** — сейчас один shared read-only ключ на весь fleet; следующий этап — выдавать ключ scored на конкретные объекты на каждом enrollment'е, leak одного ключа не компрометирует остальные устройства.
- **SMTP / Telegram delivery для Grafana alerts** — сейчас alerts видны только в Web UI, без push-уведомлений.
- **Device-Owner kiosk provisioning** — отдельный KIOSK-PROVISIONING.md + factory-reset enrollment через NFC/QR, даёт silent install обновлений + auto-grant SECURE_SETTINGS.
- **Delta-updates APK** (xDelta / bsdiff) — 170 МБ → 5-20 МБ для cellular-устройств.
- **Long-polling /sync** для near-real-time push (≤30 сек вместо ≤30 мин).
- **COSE_Sign1 manifest signature strict-mode** для encrypted distribution (currently optional).
- **Plaintext-never-on-disk** mode для top-secret material'ов (decrypt-in-memory only).
- **Chunked encrypted file delivery** для blob'ов > 100 МБ (streaming через range-requests).

Документация и репозитории

- Server-side: <https://github.com/daphate/outpost-mdm-rs>
- Client-side: <https://github.com/daphate/tactical-ar-hud> (Outpost-Android, она же «Штаб»)
- docs/DEPLOY.md — setup mdm-сервера с нуля, env-vars, systemd, nginx
- docs/PROVISION-NEW-DEVICE.md — оператору в поле, сквозной сценарий новый Ulefone из коробки
- docs/OTEL-CONTRACT.md — спецификация OTLP-данных от клиента в Grafana
- tools/MDM-DEVICE-CONTROL-CONTRACT.md (AR Hud repo) — wire-contract §1-§3 между MDM и client'ом